

DATA ITEM DESCRIPTION

Title: CYBERSECURITY TEST PLAN

Number: DI-SCRE-82140A

AMSC Number: N10361

DTIC Applicable: N/A

Preparing Activity: AS

Applicable Forms: N/A

Approval Date: 20221019

Limitation: N/A

GIDEP Applicable: N/A

Project Number: SCRE-2022-031

Use/relationship: This Data Item Description (DID) contains format, content, and intended use information for the Cybersecurity Test Plan (CTP). The CTP describes plans for security qualification testing of hardware and software supporting Risk Management Framework Assessment & Authorization (A&A), CYBERSAFE certification, and meeting the Cyber Survivability Key Performance Parameter. The CTP will also demonstrate compliance with specified system security requirements. In addition, the CTP describes the test environment to be used for the testing, identifies the tests to be performed, and provides schedules for test activities.

This DID contains the format, content, and intended use information for the data product resulting from the work task.

This DID supersedes DI-MGMT-82140.

Requirements:

1. Referenced Documents: The applicable issue of the documents cited herein, including their approval dates and dates of any applicable amendments, notices, and revisions, shall be as specified in the document.

2. Format: Contractor format is acceptable.

3. Content: The CTP shall include each of the following sections:

3.1. Test environment: This paragraph will identify one or more test sites to be used for the testing, and will be divided into the following subparagraphs to describe the test environment at the site(s). If all tests will be conducted at a single site, this paragraph and its subparagraphs will be presented only once. If multiple test sites use the same or similar test environments, they may be discussed together. Duplicative information among test site descriptions may be reduced by referencing earlier descriptions.

3.1.1. Software items. This paragraph will identify by name, number, and version, as applicable, the software items (e.g., operating systems, compilers, communications software, related applications software, databases, input files, code auditors, dynamic path analyzers, test drivers, preprocessors, test data generators, test control software, other special test software, postprocessors) necessary to perform the planned testing activities at the test site(s). This paragraph will describe the purpose of each item, describe its media (tape, disk, etc.), identify

those that are expected to be supplied by the site, and identify any classified processing or other security or privacy issues associated with the software items. Authoritative Information or data that is already provided via other collection methods, such as RMF steps shall be re-used to avoid unnecessary duplication in effort. Unique software items used in the test environment which are not identified in other authoritative sources shall be included in the software items identification.

3.1.2. Hardware and firmware items. This paragraph will identify by name, number, and version, as applicable, the computer hardware, interfacing equipment, communications equipment, test data reduction equipment, apparatus such as extra peripherals (tape drives, printers, plotters), test message generators, test timing devices, test event records, etc., and firmware items that will be used in the software test environment at the test site(s). This paragraph will describe the purpose of each item, state the period of usage and the number of each item needed, identify those that are expected to be supplied by the site, and identify any classified processing or other security or privacy issues associated with the items. Authoritative Information or data that is already provided via other collection methods, such as RMF steps shall be re-used to avoid unnecessary duplication in effort. Unique hardware and firmware items used in the test environment which are not identified in other authoritative sources shall be included in the hardware and firmware items identification.

3.1.3. Other materials. This paragraph will identify and describe any other materials needed for the testing at the test site(s). These materials may include automated security analysis tools, manuals, software listings, hardware listings, media containing data to be used in the tests, sample listings of outputs, and other forms or instructions. This paragraph will identify those items that are to be delivered to the site and those that are expected to be supplied by the site. The description will include the type, layout, and quantity of the materials, as applicable. This paragraph will identify any classified processing or other security or privacy issues associated with the items.

3.1.4. Proprietary nature, acquirer's rights, and licensing. This paragraph will identify the proprietary nature, acquirer's rights, and licensing issues associated with each element of the software test environment.

3.1.5. Installation, testing, and control. This paragraph will identify the tester's plans for performing each of the following, possibly in conjunction with personnel at the test site(s):

3.1.5.1. Acquiring or developing each element of the test environment.

3.1.5.2. Installing and testing each item of the test environment prior to its use.

3.1.5.3. Controlling and maintaining each item of the test environment.

3.1.6. Participating organizations. This paragraph will identify the organizations that will participate in the testing at the test sites(s) and the roles and responsibilities of each. The

paragraph shall also ensure that there is allotted time and physical space for government witness of any tests and the ability to review test results, without interfering with the conduct of the test.

3.1.7. Personnel. This paragraph will identify the number, type, and skill level of personnel needed during the test period at the test site(s), the dates and times they will be needed, and any special needs, such as multi-shift operation and retention of key skills to ensure continuity and consistency in extensive test programs.

3.1.8. Orientation plan. This paragraph will describe any orientation and training to be given before and during the testing. This information will be related to the personnel needs. This training may include user instruction, operator instruction, maintenance and control group instruction, and orientation briefings to staff personnel. If extensive training is anticipated, a separate plan may be developed and referenced here.

3.1.9. Tests to be performed. This paragraph will identify the tests to be performed at the test site(s).

3.1.10. Identify any required Government furnished information (GFI) and/or Government Furnished Equipment (GFE) and associated lead times require.

3.2. Test identification: This section will be divided into the following paragraphs to identify and describe each test to which this CTP applies.

3.2.1. General information. This paragraph will be divided into subparagraphs to present general information applicable to the overall testing to be performed.

3.2.1.1. Test levels. This paragraph will describe the levels at which testing will be performed, for example; component level, WRA level, or system level.

3.2.1.2. Test classes. This paragraph will describe the types or classes of tests that will be performed (for example, hardware/software penetration, IAVM, SCAP, IA Controls tests).

3.2.1.3. General test conditions. This paragraph will describe conditions that apply to all of the tests or to a group of tests. For example: "Each test will include nominal, maximum, and minimum values;" "each test of type x will use live data;" "each attempt at penetration will assume encryption is/is not enabled." Included will be a statement of the extent of testing to be performed and rationale for the extent selected.

3.2.1.4. Test progression. In cases of progressive or cumulative tests, this paragraph will explain the planned sequence or progression of tests.

3.2.1.5. Data recording, reduction, and analysis. This paragraph will identify and describe the data recording, reduction, and analysis procedures to be used during and after the tests identified in this CTP. These procedures will include, as applicable, manual, automatic, and

semiautomatic techniques for recording test results, manipulating the raw results into a form suitable for evaluation, and retaining the results of data reduction and analysis.

3.2.1.6. Classification Level. This paragraph will describe the classification level at which the tests and test results will be conducted and captured.

3.2.1.7. Risks and Hazards. This paragraph will describe the risks and hazards to be encountered during the test. For example: Data sources will be wiped out during the tests, hard drives will be encrypted without the ability to recover the data, data results will be overwritten if the test runs past certain control points, etc.

3.3. Planned tests: This paragraph will be divided into the following subparagraphs to describe the total scope of the planned testing:

3.3.1. Item(s) to be tested. This paragraph will identify a subsystem, system, or other entity by name and project-unique identifier, and will be divided into the following subparagraphs to describe the testing planned for the item(s). (Note: the "tests" in this plan are collections of test cases. There is no intent to describe each test case in this document.).

3.3.1.1. Project-unique identifier of a test. This paragraph will identify a test by project unique identifier and provide the information specified below for the test.

3.3.1.1.1. Test objective.

3.3.1.1.1.1. Threat represented, External nation state, external criminal, insider with restricted access. (This is drop down type of answer, no specifics to drive to a classified report).

3.3.1.1.1.2. Test Scope, what elements are included/excluded from this test.

3.3.1.1.1.3. Test level.

3.3.1.1.1.4. Test type or class.

3.3.1.1.2. Qualification method(s) as specified in the requirements specification.

3.3.1.1.3. Identifier of the security requirements and, if applicable, system requirements addressed by this test. (Alternatively, this information may be provided in Section (6.).

3.3.1.1.4. Special requirements (for example, 48 hours of continuous facility time, weapon simulation, extent of test, use of a special input or database).

3.3.1.1.5. Type of data to be recorded.

3.3.1.1.6. Type of data recording/reduction/analysis to be employed.

3.3.1.1.7. Assumptions and constraints, such as anticipated limitations on the test due to system or test conditions--timing, interfaces, equipment, personnel, database, etc.

3.3.1.1.8. Safety, security, and privacy considerations associated with the test.

3.4. Test schedules: This section will contain or reference the schedules for conducting the tests identified in this plan. It will include:

3.4.1. A listing or chart depicting the sites at which the testing will be scheduled and the time frames during which the testing will be conducted.

3.4.1.1. A schedule for each test site depicting the activities and events listed below, as applicable, in chronological order with supporting narrative as necessary:

3.4.1.1.1. On-site test period and periods assigned to major portions of the testing.

3.4.1.1.2. Pretest on-site period needed for setting up the test environment and other equipment, system orientation, and familiarization.

3.4.1.1.3. Collection of database/data file values, input values, and other operational data needed for the testing.

3.4.1.1.4. Conducting the tests, including planned retesting.

3.4.1.1.5. Preparation, review, and approval of the Cybersecurity Test Report (CSTR).

3.4.1.1.6. Requirements traceability. This paragraph will contain:

3.4.1.1.6.1. Traceability from each test identified in this plan to security requirements and, if applicable, system requirements it addresses.

3.4.1.1.6.2. Traceability from each security requirement and, if applicable, each system requirement covered by this test plan to the test(s) that address it.

3.5. Appendixes: Appendixes may be used to provide information published separately for convenience in document maintenance (e.g., charts, classified data). As applicable, each appendix will be referenced in the main body of the document where the data would normally have been provided. Appendixes may be bound as separate documents for ease in handling. Appendixes will be lettered alphabetically (A, B, etc.).

End of DI-SCRE-82140A